Whitepaper tecnico - Retrofit sicuro e decentralizzato per dispositivi IoT industriali

Data: 08 novembre 2026
Autore: Tiziano Ciccone
Versione: 0.5
Stato: bozza tecnica per discussione
Maturità: Questo documento descrive un'architettura allo stadio di concept (TRL 3-4). Le metriche di latenza e i budget riportati sono obiettivi di progetto, non risultati sperimentali. Non sono ancora state condotte validazioni su prototipo.
Licenza documento: CC BY-SA 4.0
Licenza firmware di riferimento: Apache-2.0
Licenza hardware di riferimento: CERN-OHL-S-2.0
Ambito: monitoraggio, allarme e autorizzazione comandi per dispositivi IoT industriali (impianti frigoriferi, celle, magazzini, macchinari con telemetria multi-parametro), nuovi ed esistenti
Lingua: in caso di discrepanza interpretativa tra la versione italiana e quella inglese, fa fede la versione inglese.

---

1. Problema e obiettivi

I dispositivi IoT industriali esistenti, come i controller di impianti frigoriferi, celle e magazzini, espongono tre criticità ricorrenti:

1. **Fiducia nei dati.** La telemetria (temperatura, umidità, stato porte, assorbimenti, pressioni, allarmi, cicli di sbrinamento, ecc.) transita da controller e broker centralizzati: un singolo punto compromesso altera o cancella la storia dei dati.
2. **Autorizzazione debole dei comandi.** La modifica di setpoint, cicli di lavoro, soglie di allarme o parametri operativi avviene spesso tramite credenziali condivise, senza audit immutabile né verifica dell'integrità del dispositivo che esegue.
3. **Latenza degli allarmi.** Le architetture cloud-first introducono dipendenza dalla connettività WAN nel percorso critico dell'allarme.

Obiettivi del progetto:

Obiettivo	Metrica di accettazione
O1 - Open source end-to-end	Firmware, hardware, specifiche e toolchain con licenze OSI
O2 - Costo basso	Tag sensore < $20 BOM; bridge < $100 BOM
O3 - Copertura retrofit e nuovi impianti	Profili hardware con firmware comune
O4 - Autenticazione e comandi veloci	Comando sul fast path < 100 ms

Obiettivo	Metrica di accettazione
O5 - Allarmi veloci	Rilevazione→notifica locale < 1 s; propagazione peer < 200 ms
O6 - Dati decentralizzati e cifrati	Nessun server centrale obbligatorio; cifratura E2E
O7 - Riduzione del rischio brevettuale	Design-around documentato + pubblicazione difensiva
O8 - Generalità del dato	Payload arbitrario multi-sensore, non solo temperatura

---

2. Allineamento ai framework di riferimento

Il progetto è progettato in coerenza con i principi di **IEC 62443** (segmentazione in zone e conduits, minimo privilegio, difesa in profondità) e **NIST SP 800-82** (sicurezza dei sistemi di controllo industriale). La separazione tra piano dati e piano comandi, l'uso di secure element e TPM come root of trust, e il degrado locale controllato sono scelte riconducibili a questi framework, senza che il documento costituisca una certificazione di conformità.

Per l'interoperabilità semantica, lo schema del payload è progettato per essere mappabile su **EPCIS 2.0** (eventi di supply chain) e su **OPC UA** (interoperabilità industriale); l'implementazione di tali mappature è oggetto delle fasi di sviluppo successive.

---

3. Principi di progettazione

- **P1 - Edge-first safety.** Le funzioni di sicurezza e allarme non dipendono dalla rete né dalla blockchain. La blockchain è fuori dal percorso critico.
- **P2 - Firmare alla fonte.** Ogni misura è firmata dal dispositivo che la produce, prima di lasciare il sensore.
- **P3 - Due piani separati.** Piano dati (telemetria, allarmi) e piano comandi (autorizzazione) hanno requisiti e tecnologie diverse e non condividono il percorso critico.
- **P4 - Separazione autorità/identità.** L'identità è crittografica e hardware-rooted; l'autorizzazione è espressa in smart contract e verificata localmente.
- **P5 - Degrado controllato.** Se la WAN cade, il sito continua a monitorare, allarmare e autorizzare localmente; la catena si riallinea dopo.
- **P6 - Compatibilità legacy.** Interfacce standard (Modbus RTU/TCP, BACnet MS/TP, contatti puliti, 4-20 mA, I²C/SPI/UART) come cittadini di prima classe.
- **P7 - Payload generico.** Il formato del dato è estensibile: qualsiasi sensore o grandezza può essere rappresentato senza modificare il protocollo di firma e trasporto.

---

4. Architettura a livelli

Flusso sintetico:

1. L0→L1: campionamento e firma ECDSA nel secure element.
2. L1→L2: invio su mesh (Thread/BLE) o bus (Modbus/BACnet/I²C/SPI).
3. L2: valutazione regole locale, emissione allarme, cifratura, invio su gossip P2P.
4. L3: aggregazione, ancoraggio Merkle orario su L5, storage su L4.
5. L5: autorizza comandi e conserva l'audit immutabile.
6. L6: gli utenti verificano autonomamente header e prove.

---

5. Profili hardware

Profilo	Target	Componenti chiave	BOM
Tag	Sensore retrofit, a batteria	MCU low-power + secure element I²C + interfaccia sensore (I²C/SPI/1-Wire) + radio mesh	$8-18
Bridge	Per macchina o gruppo	SBC/MCU potente + TPM 2.0 + radio border router + interfacce bus (RS-485, Ethernet)	$40-95
Site Node	Magazzino / sito	SBC industriale + NVMe + TPM/HSM + UPS	$200-450
Modulo Native	Dispositivi nuovi (OEM)	MCU + secure element + TrustZone, firmware identico	$10-25 a volume

Scelte tecniche comuni:

- **Root of trust:** secure element con ECDSA P-256 per Tag e Native; TPM 2.0 per Bridge e Site Node. Il TPM del Bridge è utilizzato per l'attestazione periodica e per la firma delle transazioni di ancoraggio (una volta all'ora), non per la firma di ogni singolo record di telemetria.
- **Secure boot + flash encryption** obbligatori su tutti i profili con MCU.
- **Firmware core unico** con *feature flag* per profilo: stesso codice di firma, attestazione, protocollo; cambiano solo driver e policy.
- **Capability negotiation:** il Tag dichiara risorse (batteria, radio, sensori, attuatori); il Bridge assegna il ruolo (es. Tag che diventa relay mesh se alimentato).
- **Aggiornamento hardware senza fork software:** l'aggiunta di un profilo più potente abilita funzioni (validatore completo, storage) senza modificare il contratto dati.

---

6. Identità, root of trust e attestazione

6.1 Identità del dispositivo

- Coppia di chiavi generata **dentro** il secure element in fabbrica; la chiave privata non è mai esportabile.
- Identificatore decentralizzato `did:key` (o `did:pkh`) derivato dalla chiave pubblica; certificato X.509 opzionale per interoperabilità enterprise.
- Registrazione on-chain: hash della chiave pubblica + metadati (modello, sito, data) in un registry contract.

6.2 Attestazione

- **Measured boot:** hash del firmware e della configurazione misurati a ogni avvio.
- **Attestation report** firmato dalla chiave del dispositivo, contenente: misura firmware, contatore anti-rollback, nonce della sfida, stato secure boot.
- **Verifica:** il Bridge (e periodicamente il contratto) verifica il report contro la misura attesa pubblicata on-chain dal manutentore.
- **Attestazione periodica** (es. ogni 15 min) per rilevare dispositivi compromessi o manomessi.
- **Sincronizzazione temporale:** tra Tag e Bridge avviene tramite NTP o PTP; la deriva del clock è monitorata e corretta prima dell'ancoraggio Merkle.

6.3 Gestione chiavi

- Rotazione chiave supportata da contratto: nuova chiave firmata dalla vecchia + autorizzazione on-chain.
- Revoca: lista di revoca on-chain consultata dal Bridge e dai peer; il Tag revocato non può più firmare comandi accettati.
- Decommissioning: cancellazione chiave nel secure element + evento di revoca on-chain.

---

7. Piano dati: telemetria decentralizzata multi-parametro

Pipeline:

1. **Campionamento** (Tag): intervallo configurabile per ciascun sensore; payload definito da uno schema estensibile (JSON/CBOR) che ammette grandezze arbitrarie (temperatura, umidità, stato, correnti, pressioni, vibrazioni, contatori, eventi).
2. **Firma alla fonte:** ogni record è firmato con ECDSA; include contatore monotono (anti-replay) e timestamp del dispositivo.
3. **Buffer locale:** ring buffer su flash con politica di overwrite e journal.
4. **Cifratura E2E:** AES-256-GCM con chiave di sito; il Bridge non può leggere il payload se non è autorizzato (capability).
5. **Pubblicazione su IPFS:** blocco content-addressed → CID.
6. **Ancoraggio:** ogni ora il Bridge calcola la radice Merkle dei CID del periodo e la scrive on-chain.

7. **Accesso:** gli utenti autorizzati ricevono una capability UCAN che consente la decifratura e il recupero dei CID.

Proprietà: nessun server centrale possiede il dato; l'integrità è verificabile matematicamente; la catena contiene solo hash (nessun dato personale o commerciale). Lo schema del payload è versionato e aperto, così nuovi tipi di sensore non richiedono modifiche al protocollo.

---

8. Piano comandi: autorizzazione veloce

Il requisito "massima sicurezza e massima velocità" è risolto con **due percorsi**.

8.1 Percorso freddo (autorizzazione on-chain)

1. L'operatore si autentica (MFA/SSO) e firma un *command envelope*.
2. Il contratto verifica: ruolo, stato del dispositivo, attestazione valida, policy del sito.
3. Il contratto emette un evento di autorizzazione con nonce e scadenza.
4. Il Bridge verifica la prova (header/evento) tramite light client e inoltra il comando al Tag.
5. Il Tag verifica firma, nonce e scadenza nel secure element, poi esegue.

Latenza tipica: 1-4 s (dominata dal consenso).

8.2 Percorso caldo (session ticket pre-autorizzato)

Per i comandi frequenti e ripetitivi (setpoint, cicli, silenziamento allarmi, parametri operativi):

1. Una volta per sessione, il contratto autorizza un **session ticket** (PASETO v4.public o biscuit) con: ambito, device target, parametri ammessi, scadenza breve (es. 15 min), limite di utilizzo.
2. Il ticket è conservato dal Bridge e dal client.
3. I comandi successivi viaggiano come **envelope firmato + ticket**, verificati localmente dal Tag senza toccare la catena.
4. Il Bridge invia on-chain un **riepilogo batch** dei comandi eseguiti ogni N minuti, per l'audit.

Latenza tipica: 30-90 ms. La latenza del percorso caldo è dominata dal tempo di verifica crittografica nel secure element del Tag; il valore indicato è un target che presuppone un'ottimizzazione del firmware e dell'interfaccia I²C.

Sicurezza del percorso caldo: il ticket è limitato in ambito e durata; il contatore anti-replay è nel secure element; la revoca del ticket è possibile on-chain e viene propagata ai Bridge in pochi secondi; ogni esecuzione è registrata localmente e ancorata in batch.

8.3 Regole di sicurezza non negoziabili

- Nessun comando può violare i **limiti fisici di safety** codificati nel firmware (es. intervallo ammesso per ciascun parametro, durata massima di un ciclo, soglie di allarme minime).
- I comandi che modificano la safety richiedono sempre il percorso freddo.

- Doppia autorizzazione per operazioni critiche (es. disattivazione di un allarme critico).

---

9. Piano allarmi: edge-first, P2P

Catena di rilevazione e propagazione:

1. **Valutazione locale** (Bridge o Tag, a seconda del profilo): regole con finestra temporale e isteresi su qualsiasi grandezza del payload (es. T > soglia per 10 min, corrente anomala, porta aperta, pressione fuori range).
2. **Allarme locale immediato:** relay/sirena/contatto pulito sul Bridge. Nessuna rete richiesta.
3. **Pubblicazione su topic prioritario** con GossipSub (libp2p): messaggio firmato, cifrato, con TTL e priorità.
4. **Propagazione ai peer** (altri Bridge del sito e dei siti vicini) in < 200 ms su LAN.
5. **Notifica utente:** WebRTC/WebTransport verso i client connessi; relay push per i client offline; fallback SMS/e-mail via gateway locale.
6. **Ancoraggio asincrono:** l'evento è inserito nel batch Merkle successivo (2-10 s), fuori dal percorso critico.

Budget di latenza:

Tratta	Target
Sensore → firma	20-100 ms
Firma → valutazione regola	10-50 ms
Rilevazione → attuatore locale	< 500 ms
Bridge → peer (LAN)	20-100 ms
Bridge → notifica client	200-800 ms
Ancoraggio on-chain	2-10 s (asincrono)

Regola architetturale: l'allarme viene emesso localmente dal Bridge o dal Tag in base a regole codificate nel firmware. La blockchain riceve l'evento solo in un secondo momento, per l'audit, e non può ritardarne o bloccarne l'emissione.

---

10. Sicurezza: modello di minaccia e contromisure

Minaccia	Contromisura
Manomissione fisica del Tag	Secure element, rilevamento apertura, chiave non estraibile

Minaccia	Contromisura
Firmware malevolo	Secure boot, flash encryption, OTA firmato, anti-rollback
Replay di comandi	Contatore monotono nel SE + nonce + scadenza ticket
MITM sul mesh	Noise Protocol (pattern IK/XX), sessioni autenticate
Compromissione del Bridge	Attestazione periodica, principio di minimo privilegio, segregazione rete
Dispositivo clonato	Attestazione con nonce, registry on-chain, revoca
Perdita di connettività WAN	Degrado locale: monitoraggio, allarmi e ticket restano operativi
Accesso non autorizzato ai dati	Cifratura E2E, capability UCAN, chiavi per sito

Crittografia: ECDSA P-256 (firma), ECDH P-256 (scambio), AES-256-GCM (payload), SHA-256 (hash), Noise (trasporto P2P).

---

11. Passaggi essenziali del ciclo di vita

11.1 Provisioning in fabbrica

1. Generazione chiave nel secure element.
2. Scrittura del certificato/identità e del modello.
3. Secure boot e flash encryption abilitati e verificati.
4. Registrazione dell'hash della chiave pubblica nel registry (offline o on-chain).
5. Etichettatura con QR contenente il DID.

> **Nota sulla supply chain.** Il processo di provisioning in fabbrica e la gestione delle chiavi durante la produzione saranno oggetto di una procedura separata, che includerà controlli contro l'iniezione di componenti contraffatti e la verifica dell'integrità della BOM.

11.2 Installazione e pairing

1. Scansione QR da parte del Bridge.
2. Handshake Noise: il Tag verifica l'identità del Bridge, il Bridge verifica l'attestazione del Tag.
3. Assegnazione al sito e alla macchina; definizione delle regole e dello schema del payload.
4. Distribuzione della chiave di sito (cifrata per il Tag).
5. Primo record firmato e ancorato.

11.3 Esercizio

1. Campionamento e firma continui.
2. Valutazione regole locali e allarmi.
3. Pubblicazione su IPFS e ancoraggio Merkle orario.
4. Attestazione periodica.
5. Audit dei comandi in batch.

11.4 Comandi

1. Autenticazione utente e firma envelope.
2. Percorso freddo o caldo (sezione 8).
3. Verifica locale nel secure element.
4. Esecuzione e registrazione.
5. Ancoraggio dell'audit.

11.5 Aggiornamento firmware (OTA)

1. Firma del manifest con chiave di release.
2. Distribuzione via IPFS (CID nel manifest).
3. Verifica firma e hash sul dispositivo.
4. Scrittura su partizione B e reboot con rollback automatico in caso di fallimento.
5. Aggiornamento della misura attesa nel registry.

11.6 Rotazione e revoca

1. Nuova chiave generata nel SE.
2. Transazione di rotazione firmata dalla vecchia chiave.
3. Propagazione della revoca ai Bridge e ai peer.
4. Aggiornamento del registry.

11.7 Dismissione

1. Cancellazione della chiave nel SE.
2. Evento di revoca on-chain.
3. Anonimizzazione dei metadati del sito.

---

12. Interoperabilità con l'esistente

- **Modbus RTU/TCP e BACnet MS/TP:** il Bridge agisce da gateway, leggendo registri e oggetti standard e mappandoli su record firmati.
- **Contatti puliti, 4-20 mA, I²C/SPI/UART:** interfaccia diretta per sensori e attuatori legacy.

- **Controller esistenti:** nessuna sostituzione richiesta; il progetto si sovrappone come livello di fiducia e audit.
- **MQTT:** supportato come adattatore opzionale, mai come percorso critico.
- **Schema payload aperto:** nuovi tipi di sensore o grandezze si aggiungono con un'estensione versionata, senza modificare firma e trasporto.

---

13. Validazione e prossimi passi

Le fasi successive prevedono la misurazione sperimentale delle latenze dichiarate, l'analisi del costo totale di proprietà (TCO) e la verifica della mappatura su EPCIS 2.0 e OPC UA su un impianto pilota.

Criteri di successo proposti per il pilota:

- Latenza del percorso caldo ≤ 100 ms (p95) su 10.000 comandi.
- Propagazione dell'allarme al peer ≤ 200 ms (p95) su LAN.
- Integrità verificabile del 100% dei record ancorati.
- Funzionamento completo in degrado WAN per almeno 72 ore consecutive.

Appendice A - Struttura del record di telemetria (esempio multi-parametro)

Lo schema `fridge.v1` è un esempio; altri domini utilizzano identificatori diversi (es. `pump.v1`, `hvac.v1`) con la stessa struttura di envelope.

```
{
  "v": 1,
  "did": "did:key:z6Mk...",
  "site": "sha256:...",
  "seq": 1048577,
  "ts": "2026-11-08T09:14:22Z",
  "schema": "fridge.v1",
  "data": {
    "t_c": -18.42,
    "rh": 71.2,
    "door": 0,
    "compressor_current_a": 4.12,
    "defrost_active": false,
    "pressure_bar": 2.31
  },
  "prev": "sha256:...",
  "sig": "ecdsa-p256:..."
}
```

Appendice B - Struttura del command envelope

```
{
  "v": 1,
  "cmd": "set_setpoint",
  "target": "did:key:z6Mk...",
  "params": { "t_c": -20.0 },
  "nonce": "0x9f3a...",
  "exp": 1762590000,
  "ticket": "paseto-v4.public:...",
  "issuer": "did:key:z6Mk...",
  "sig": "ecdsa-p256:..."
}
```

Appendice C - Criteri di scelta della blockchain

- **Permissioned** (es. Hyperledger Besu/Fabric) se il consorzio controlla i validatori e serve throughput prevedibile.
- **L2 pubblica** se serve verificabilità pubblica e resistenza alla censura.
- Requisiti minimi: light client efficiente, finalità < 5 s, costi di ancoraggio trascurabili, supporto a prove Merkle, API stabili. Le latenze del percorso freddo (1-4 s) si riferiscono a una blockchain permissioned o a un Layer-2 con finalità rapida; l'uso di una mainnet pubblica comporterebbe latenze superiori e costi di gas non trascurabili.

© 2026 Tiziano Ciccone. Questo documento è rilasciato con licenza CC BY-SA 4.0.

Fine documento - v0.5 (IT)